API UEH Student

Base URL: `https://api.ngoisaoviet.info`

Chỉ dùng HTTPS. Request và response là JSON (`Content-Type: application/json`).

API	Method	Đường dẫn	Cần token
Đăng nhập	`POST`	`/api/login`	Không
Làm mới token	`POST`	`/api/refresh-token`	Không
Thông tin sinh viên	`GET`	`/api/student-info`	Có
Điểm danh	`POST`	`/api/attendance`	Có

Bắt đầu nhanh

```
# 1. Đăng nhập, lấy token
curl -X POST https://api.ngoisaoviet.info/api/login \
  -H "Content-Type: application/json" \
  -d '{"mssv":"31240000000","mat_khau":"********"}'

# 2. Gọi API cần đăng nhập
curl https://api.ngoisaoviet.info/api/student-info \
  -H "Authorization: Bearer <token>"
```

Quy tắc token

- Gửi `token` trong header `Authorization: Bearer <token>` cho mọi API cần đăng nhập.
- `token` sống **60 phút**. Gặp `401` thì gọi làm mới token, rồi gọi lại API.
- `refresh_token` sống **7 ngày**. Hết hạn hoặc bị từ chối thì đăng nhập lại.
- Danh tính lấy từ token. Sinh viên chỉ thao tác được trên dữ liệu của chính mình.

---

1. Đăng nhập

`POST /api/login`

Trường	Kiểu	Bắt buộc
`mssv`	string	Có
`mat_khau`	string	Có

`200`

```
{
  "token": "eyJhbGciOiJIUzI1NiIs...",
  "refresh_token": "Wm9vbWVy...==",
  "token_type": "Bearer",
  "expires_in": 3600
}
```

`expires_in` tính bằng giây.

Mã	Khi nào
`401`	Sai MSSV hoặc mật khẩu: `{ "message": "MSSV hoặc mật khẩu không đúng." }`
`400`	Thiếu trường bắt buộc (xem lỗi 400)

2. Làm mới token

`POST /api/refresh-token`

Trường	Kiểu	Bắt buộc
`refresh_token`	string	Có

`200`: giống đăng nhập, trả cặp `token` và `refresh_token` **mới**.

Mã	Khi nào
`401`	Refresh token sai, hết hạn hoặc đã bị thu hồi: `{ "message": "Refresh token không hợp lệ hoặc đã hết hạn." }`
`400`	Thiếu `refresh_token`

> **Mỗi refresh token chỉ dùng một lần.**
>
> - Sau khi refresh, phải lưu ngay cặp token mới và bỏ cặp cũ.
> - Không gửi hai request refresh song song với cùng một token.
> - Dùng lại token đã thu hồi sẽ thu hồi **toàn bộ** refresh token của sinh viên đó, buộc đăng nhập lại.
> - Admin đổi mật khẩu sinh viên cũng thu hồi mọi refresh token cũ.

3. Thông tin sinh viên

`GET /api/student-info`

`200`

```
{
  "uid": 1,
  "mssv": "31240000000",
  "hoVaTen": "Nguyễn Văn A",
  "ngaySinh": "2006-10-12T00:00:00",
  "gioiTinh": true,
  "nienKhoa": "DHCQK50",
  "noiSinh": "TP. Hồ Chí Minh",
  "heDaoTao": "ĐHCQ",
  "nienHoc": "2024 - 2027",
  "hinhDaiDien": "https://randomuser.me/api/portraits/men/42.jpg"
}
```

`gioiTinh`: `true` là Nam, `false` là Nữ. Response không có mật khẩu.

Mã	Khi nào
`401`	Thiếu token, token sai hoặc hết hạn (body rỗng)
`404`	Sinh viên không còn tồn tại: `{ "message": "Không tìm thấy sinh viên." }`

4. Điểm danh

`POST /api/attendance`

Admin tạo đợt trên web quản trị và nhận **mã đợt 6 ký tự** (chữ hoa và số, ví dụ `A7K2P9`). **Mã QR chứa đúng chuỗi này.** App quét QR, lấy chuỗi làm `code` rồi gọi API. Sinh viên cũng có thể nhập tay.

Trường	Kiểu	Bắt buộc	Ghi chú
`code`	string	Có	Không phân biệt hoa thường, tự bỏ khoảng trắng hai đầu
`latitude`	number	Khi đợt yêu cầu vị trí	Từ -90 đến 90
`longitude`	number	Khi đợt yêu cầu vị trí	Từ -180 đến 180

```
{ "code": "A7K2P9", "latitude": 10.7610401, "longitude": 106.6684314 }
```

`200`

```
{
  "message": "Điểm danh thành công.",
  "sessionName": "Điểm danh buổi 1",
  "mssv": "31240000000",
  "hoVaTen": "Nguyễn Văn A",
  "checkedInAt": "2026-09-30T09:15:32.1234567",
  "distanceMeters": 12.4
}
```

- `checkedInAt`: giờ do **server** ghi nhận, theo giờ Việt Nam (UTC+7).
- `distanceMeters`: khoảng cách tới địa điểm (mét), `null` nếu đợt không yêu cầu vị trí.

Lỗi (body dạng `{ "message": "..." }`)

Mã	Message	Nguyên nhân
`404`	Mã điểm danh không tồn tại.	Sai mã
`409`	**Bạn đã điểm danh bằng mã này rồi.**	Mỗi sinh viên chỉ điểm danh một lần cho mỗi đợt
`400`	Đợt điểm danh chưa bắt đầu.	Chưa đến giờ
`400`	Đợt điểm danh đã kết thúc.	Quá giờ
`400`	Đợt điểm danh này yêu cầu vị trí (latitude, longitude).	Thiếu tọa độ
`400`	Tọa độ không hợp lệ.	Ngoài phạm vi
`403`	Bạn đang ở ngoài phạm vi điểm danh (cách X m, cho phép Y m).	Quá xa địa điểm
`401`	(body rỗng)	Thiếu token, token sai hoặc hết hạn

Địa điểm: cố định tại **Cơ sở B (B1-B2)**, 279 Nguyễn Tri Phương, P. Diên Hồng, TP. Hồ Chí Minh, tọa độ `10.7610401, 106.6684314`. Bán kính cho phép do admin chọn cho từng đợt: 50, 100, 200, 300, 500 hoặc 1000 m.

Điểm danh bị từ chối (sai vị trí, ngoài giờ, ...) thì **chưa tính là đã điểm danh**, sinh viên thử lại được.

Lỗi 400: thiếu hoặc sai dữ liệu

Body thiếu trường bắt buộc hoặc JSON sai định dạng sẽ nhận `400` theo chuẩn ASP.NET Core:

```
{
  "title": "One or more validation errors occurred.",
  "status": 400,
  "errors": { "MSSV": ["The MSSV field is required."] }
}
```

Lỗi nghiệp vụ (`401`, `403`, `404`, `409` và các lỗi `400` ở mục điểm danh) thì đọc trường `message`.

Ví dụ JavaScript

Tự làm mới token khi gặp `401` và chỉ thử lại một lần.

```
const BASE = "https://api.ngoisaoviet.info";
let tokens = null; // { token, refresh_token }

async function post(path, body, token) {
  return fetch(`${BASE}${path}`, {
    method: "POST",
    headers: {
      "Content-Type": "application/json",
      ...(token && { Authorization: `Bearer ${token}` }),
    },
    body: JSON.stringify(body),
  });
}

async function login(mssv, matKhau) {
  const res = await post("/api/login", { mssv, mat_khau: matKhau });
  if (!res.ok) throw new Error((await res.json()).message);
  tokens = await res.json();
}

async function refresh() {
  const res = await post("/api/refresh-token", { refresh_token: tokens.refresh_token });
  if (!res.ok) { tokens = null; return false; } // phải đăng nhập lại
  tokens = await res.json();                    // lưu ngay cặp token mới
  return true;
}

async function callApi(method, path, body, retry = true) {
  const res = await fetch(`${BASE}${path}`, {
    method,
    headers: { "Content-Type": "application/json", Authorization: `Bearer
${tokens.token}` },
    body: body && JSON.stringify(body),
  });
  if (res.status === 401 && retry && (await refresh())) return callApi(method, path,
body, false);
  return res;
}

await login("31240000000", "********");
const info = await (await callApi("GET", "/api/student-info")).json();
const result = await callApi("POST", "/api/attendance", {
  code: "A7K2P9", latitude: 10.7610401, longitude: 106.6684314,
});
console.log(result.status, await result.json());
```

Lưu ý bảo mật

- Lưu `token` và `refresh_token` ở nơi an toàn (Keychain trên iOS, Keystore trên Android), không ghi log.
- Không nhúng mật khẩu vào app, chỉ hỏi sinh viên khi đăng nhập.

- Tọa độ do thiết bị gửi lên, server chỉ kiểm tra được khoảng cách. App nên lấy tọa độ trực tiếp từ dịch vụ định vị của hệ điều hành, không cho người dùng tự nhập.